LAB 5: STATIC CODE ANALYSIS

Courier & Parcel Tracking System

Tools: Pylint, Bandit and Flake8

Name:Shivanand

SRN:PES2UG24CS472

Section :H

1. Objective

To find and fix code quality, security and formatting problems in a Python parcel tracking program using Pylint, Bandit and Flake8.

2. Program Used

The program books parcels, changes delivery status, tracks parcels, checks courier status, calculates shipping cost and generates a delivery OTP.3. Tools Used

Tool	Purpose
Pylint	Checks Python code quality and coding practices.
Bandit	Checks common security problems in Python code.
Flake8	Checks code style and formatting.

4. Problems Found and Fixed

Problem	Tool	Fix
Mutable default argument	Pylint	Changed the default value from `[]` to `None`.
Broad exception	Pylint	Changed broad exception handling to `KeyError`.
Missing documentation	Pylint	Added module and function documentation.
Non-standard names	Pylint	Used clear `snake_case` names.
Unsafe temporary file	Bandit	Used `NamedTemporaryFile` instead of `mktemp`.
Weak OTP generation	Bandit	Used `secrets.randbelow()` instead of `random.randint()`.
Unsafe subprocess code	Bandit	Removed the unused subprocess helper.
Formatting errors	Flake8	Fixed spaces, comments, and blank lines.

5. Pylint Results

Before: 4.91/10

After: 10.00/10

The final code achieved a Pylint score of 10.00/10.

Pylint – Before

```
D:\L5_35_parcel_tracker>python -m pylint parcel_tracker_before.py
************* Module parcel_tracker_before
parcel_tracker_before.py:1:0: C0114: Missing module docstring (missing-module-docstring)
parcel_tracker_before.py:11:0: C0116: Missing function or method docstring (missing-function-docstring)
parcel_tracker_before.py:11:0: C0103: Function name "bookParcel" doesn't conform to snake_case naming style (invalid-nam
e)
parcel_tracker_before.py:11:33: C0103: Argument name "weightKg" doesn't conform to snake_case naming style (invalid-name
)
parcel_tracker_before.py:11:0: W0102: Dangerous default value [] as argument (dangerous-default-value)
parcel_tracker_before.py:12:4: C0103: Variable name "trackingId" doesn't conform to snake_case naming style (invalid-nam
e)
parcel_tracker_before.py:20:0: C0116: Missing function or method docstring (missing-function-docstring)
parcel_tracker_before.py:20:0: C0103: Function name "advanceStatus" doesn't conform to snake_case naming style (invalid-
name)
parcel_tracker_before.py:20:18: C0103: Argument name "trackingId" doesn't conform to snake_case naming style (invalid-na
me)
parcel_tracker_before.py:27:0: C0116: Missing function or method docstring (missing-function-docstring)
parcel_tracker_before.py:27:0: C0103: Function name "shippingCost" doesn't conform to snake_case naming style (invalid-n
ame)
parcel_tracker_before.py:27:17: C0103: Argument name "weightKg" doesn't conform to snake_case naming style (invalid-name
)
parcel_tracker_before.py:34:0: C0116: Missing function or method docstring (missing-function-docstring)
parcel_tracker_before.py:34:0: C0103: Function name "trackParcel" doesn't conform to snake_case naming style (invalid-na
me)
parcel_tracker_before.py:34:16: C0103: Argument name "trackingId" doesn't conform to snake_case naming style (invalid-na
me)
```

```
me)
parcel_tracker_before.py:34:16: C0103: Argument name "trackingId" doesn't conform to snake_case naming style (invalid-na
me)
parcel_tracker_before.py:37:11: W0718: Catching too general exception Exception (broad-exception-caught)
parcel_tracker_before.py:43:0: C0116: Missing function or method docstring (missing-function-docstring)
parcel_tracker_before.py:43:0: C0103: Function name "isWithCourier" doesn't conform to snake_case naming style (invalid-
name)
parcel_tracker_before.py:43:18: C0103: Argument name "trackingId" doesn't conform to snake_case naming style (invalid-na
me)
parcel_tracker_before.py:45:11: R1714: Consider merging these comparisons with 'in' by using 'status in ('Picked Up', 'I
n Transit')'. Use a set instead if elements are hashable. (consider-using-in)
parcel_tracker_before.py:48:0: C0116: Missing function or method docstring (missing-function-docstring)
parcel_tracker_before.py:48:0: C0103: Function name "labelPath" doesn't conform to snake_case naming style (invalid-name
)
parcel_tracker_before.py:53:0: C0116: Missing function or method docstring (missing-function-docstring)
parcel_tracker_before.py:53:0: C0103: Function name "pingHub" doesn't conform to snake_case naming style (invalid-name)
parcel_tracker_before.py:53:12: C0103: Argument name "hubAddress" doesn't conform to snake_case naming style (invalid-na
me)
parcel_tracker_before.py:58:0: C0116: Missing function or method docstring (missing-function-docstring)
parcel_tracker_before.py:67:8: C0103: Variable name "trackingId" doesn't conform to snake_case naming style (invalid-nam
e)

-------------------------------------------------------------------
Your code has been rated at 4.91/10 (previous run: 4.91/10, +0.00)


D:\L5_35_parcel_tracker>
```

Pylint – After

```
D:\L5_35_parcel_tracker>python -m pylint parcel_tracker_after.py

--------------------------------------------------------------------
Your code has been rated at 10.00/10 (previous run: 10.00/10, +0.00)


D:\L5_35_parcel_tracker>
```

6. Bandit Results

Before: Security issues were reported.

After: No issues identified.

The final code has no reported Bandit security issues.

Bandit – Before

```
D:\L5_35_parcel_tracker>python -m bandit -r parcel_tracker_before.py
[main]  INFO    profile include tests: None
[main]  INFO    profile exclude tests: None
[main]  INFO    cli include tests: None
[main]  INFO    cli exclude tests: None
[main]  INFO    running on Python 3.13.12
Run started:2026-10-14 13:17:57.899062+00:00

Test results:
>> Issue: [B404:blacklist] Consider possible security implications associated with the subprocess module.
   Severity: Low   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_imports.html#b404-import-subprocess
   Location: .\parcel_tracker_before.py:2:0
1       import random
2       import subprocess
3       import tempfile

--------------------------------------------------
>> Issue: [B306:blacklist] Use of insecure and deprecated function (mktemp).
   Severity: Medium   Confidence: High
   CWE: CWE-377 (https://cwe.mitre.org/data/definitions/377.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b306-mktemp-q
   Location: .\parcel_tracker_before.py:50:11
49          # Helper kept for the lab: not called by the demo
50          return tempfile.mktemp(suffix=".txt")
51
```

```
--------------------------------------------------
>> Issue: [B602:subprocess_popen_with_shell_equals_true] subprocess call with shell=True identified, security issue.
   Severity: High   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b602_subprocess_popen_with_shell_equals_true.html
   Location: .\parcel_tracker_before.py:55:11
54          # Helper kept for the lab: not called by the demo
55          return subprocess.check_output("ping -c 1 " + hubAddress, shell=True)
56

--------------------------------------------------
>> Issue: [B311:blacklist] Standard pseudo-random generators are not suitable for security/cryptographic purposes.
   Severity: Low   Confidence: High
   CWE: CWE-330 (https://cwe.mitre.org/data/definitions/330.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b311-random
   Location: .\parcel_tracker_before.py:72:19
71          print(trackParcel("TRK00000")) # unknown id
72          delivery_otp = random.randint(1000, 9999)
73          print("Delivery OTP for", third, "is", delivery_otp)

--------------------------------------------------

Code scanned:
        Total lines of code: 56
        Total lines skipped (#nosec): 0
```

```
Run metrics:
        Total issues (by severity):
                Undefined: 0
                Low: 2
                Medium: 1
                High: 1
        Total issues (by confidence):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 4
Files skipped (0):

D:\L5_35_parcel_tracker>
```

Bandit – After

```
D:\L5_35_parcel_tracker>python -m bandit -r parcel_tracker_after.py
[main]  INFO    profile include tests: None
[main]  INFO    profile exclude tests: None
[main]  INFO    cli include tests: None
[main]  INFO    cli exclude tests: None
[main]  INFO    running on Python 3.13.12
Run started:2026-10-14 13:21:38.063955+00:00

Test results:
        No issues identified.

Code scanned:
        Total lines of code: 76
        Total lines skipped (#nosec): 0

Run metrics:
        Total issues (by severity):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 0
        Total issues (by confidence):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 0
Files skipped (0):

D:\L5_35_parcel_tracker>
```

7. Flake8 Results

Before: Formatting errors were reported.

After: No errors were reported.

The final code follows the required Flake8 formatting rules.

Flake8 – Before

```
D:\L5_35_parcel_tracker>python -m flake8 parcel_tracker_before.py
parcel_tracker_before.py:28:9: E225 missing whitespace around operator
parcel_tracker_before.py:71:35: E261 at least two spaces before inline comment
parcel_tracker_before.py:74:34: E231 missing whitespace after ','
parcel_tracker_before.py:75:1: E305 expected 2 blank lines after class or function definition, found 0

D:\L5_35_parcel_tracker>
```

Flake8 – After

```
D:\L5_35_parcel_tracker>python -m flake8 parcel_tracker_after.py

D:\L5_35_parcel_tracker>
```

8. Program Verification

After fixing the issues, the program was run again. The parcel booking, delivery status, courier status, shipping cost, unknown tracking ID and OTP features worked correctly.

9. Reflection

What did I learn?

Static analysis can find code problems before they cause problems during execution.

Which tool was useful?

Bandit was useful for security problems and Pylint was useful for code quality.

How did the tools improve the code?

They helped make the code safer, clearer and better formatted.

How can these tools be used in a project?

They can be added to the development and CI/CD process to check code automatically.

11. Conclusion

The code was checked using Pylint, Bandit and Flake8. The identified quality, security and formatting problems were fixed. The final program works correctly and achieved a Pylint score of 10.00/10 with no final Bandit or Flake8 issues.